

2.

SAQ SELECTION GUIDELINES

What criteria should we use to
better decide which SAQ to
take?



ASSESSMENT

ASSESSMENT **SAQ SELECTION GUIDELINES**

There is an official PCI DSS guide on how to select your SAQ, but we can summarize some of the guidelines in this lesson.

- There are various questions that you can ask yourself to immediately determine your category in terms of the SAQs;
- The SAQ-D for merchants is the “kitchen sink” - the category you end up if you don’t fulfill any of the previous conditions (and the most demanding category, too);
- These categories usually depend on the types of transactions you accept, as well as the data that you store;

ASSESSMENT

SAQ SELECTION GUIDELINES

You can start by asking:

- Am I service provider?
 - If yes: SAQ D for SPs;
- Do I store any card data at all?
 - If yes: SAQ D for Merchants;
- Do I use specific devices?
 - P2PE solutions? If yes: SAQ P2PE;
 - SPoC solutions? If yes: SAQ SPoC;

Then, we have two branches, depending on whether we accept:

- CP/MOTO transactions;
- Electronic transactions;





ASSESSMENT

ASSESSMENT SAQ SELECTION GUIDELINES

If we accept CP or MOTO transactions, do we:

- Fully outsource payment? (If yes: SAQ A);
- Use local devices?
 - Imprint or dial-out machines (no internet) (SAQ B);
 - PTS-approved devices with Internet (SAQ B-IP);
- Use Internet-connected apps?
 - Payment app or POS with Internet? (SAQ C);
 - Web browser with 3rd-party redirect? (SAQ C-VT);

If we accept electronic transactions, do we:

- Fully outsource payment? (If yes: SAQ A);
- Partially outsource (third party does some parts of the payment process)? (If yes: SAQ A-EP);
- Manage the payment system? (If yes: SAQ D Merchants);

ASSESSMENT

SAQ SELECTION GUIDELINES

EXAMPLES

/01 STORE DIGITAL DATA? D

A good mnemonic to keep in mind is that, if you store electronic data, you are immediately slotted into SAQ D. Others allow paper data, for example, but no digital.

/02 P2PE/SPoC ARE DISTINCT

SAQs P2Pe and SPoC seem similar (you use specific approved hardware). P2PE uses a POI, however, and SPoC an SCRIP device. SPoC is only CP, as well.

/03 REMEMBER CHANGES

Remember changes change your SAQ, too. If you fully outsource electronic payments (SAQ A), but change website to partly outsource, you're now SAQ A-EP!

ASSESSMENT

SAQ SELECTION GUIDELINES

KEY TAKEAWAYS

/01 SPS, DATA, HARDWARE

To help inform which SAQ to take, we first ask whether we are a service provider (SAQ D SPS), store data (SAQ D Merchants), or use specific devices (SAQ P2PE/SPoC)

/03 ELECTRONIC: A, A-EP, D

For electronic merchants, we can fully outsource payments (SAQ A), partially outsource them (SAQ A-EP), or own the payment gateway (SAQ D).

/02 CP/MOTO: A, B/B-IP, C/C-VT

For card-present or MOTO merchants, we can fully outsource (SAQ A), use local devices (SAQ B or B-IP), or Internet-connected apps (SAQ C or C-VT).